Infrastructure, Data Standards and Data Management for Federated Learning in Biological Countermeasures

Preliminary Notes: Concerns and an Investigation Agenda

Evidence current as of 25 September 2026

Compiled 30 October 2026

Abstract

These are preliminary notes, not a standard. They set out what appears worth *worrying about* when building federated learning (FL) pipelines for medical and biological countermeasure work, what the published literature does and does not establish about each worry, and which questions seem to need real investigation before anyone commits to an architecture.

Nothing here should be read as a requirement or a compliance baseline. Several sections record open questions whose answers would change the design substantially, and at least one — whether purely computational biological design work falls within the scope of current US high-risk life-sciences research policy (Section 6) — could determine whether a programme of this kind is in regulatory scope at all. The architecture sketch in Section 8 is offered as a straw man to argue with rather than a recommendation.

Claims carry evidence markers (Section 2). The appendix records what could and could not be verified, and why that limitation is itself material.

Contents

1 Purpose and status **2**

2 How to read this document **2**

3 Starting point: what federation appears to buy **3**
3.1 The encouraging evidence . . . 3
3.2 The counterweight, which deserves equal billing . . . 3
3.3 What inverts relative to centralised machine learning . . . 3
3.4 Federation may not be the right answer . . . 4

4 Concerns **4**
4.1 Scientific validity and site confounding . . . 4
4.2 Data semantics: what a row means at every site . . . 5
4.3 Data quality without being able to look . . . 7
4.4 Privacy: stating precisely what each mechanism guarantees . . . 8
4.5 Adversarial robustness, where the literature genuinely disagrees . . . 9
4.6 Reliability when partial participation is normal . . . 10

5 Regulatory and governance currency **10**
5.1 Medical device and pharmaceutical regimes 10
5.2 EU data and AI law 11
5.3 Security and AI-risk frameworks 12

6 Biosecurity and dual-use: the largest open question **12**

7 Documentation and reporting **14**

8 An architecture sketch, offered as a straw man **14**

9 Consolidated investigation agenda **15**

A Verification limits **16**

1 Purpose and status

The question these notes respond to is: *how should one think about infrastructure, data standards and data management so that federated pipelines for biological countermeasures are safe, secure and reliable?*

They are deliberately framed as concerns rather than answers, for three reasons.

- **The evidence base is thinner than the enthusiasm.** A 2024 review of healthcare FL concluded that "the vast majority are not appropriate for clinical use" [37]. Prescribing a standard on top of that literature would overstate what is known.
- **Several key questions are genuinely open.** Where the literature is contested — notably adversarial robustness (Section 4.5) — the useful output is a statement of the disagreement and what would resolve it, not a picked side.
- **The regulatory ground is moving fast.** Between early 2025 and mid 2026, the governing US dual-use research policy was rescinded and replaced, an AI executive order was rescinded, EU AI Act high-risk obligations were deferred, and an export-control rule on AI model weights was withdrawn. Section 5 has a short half-life by construction.

What these notes are not. Not a specification, not a controls baseline, not legal or regulatory advice, and not a claim that federated learning is the right architecture for any particular programme — Section 3.4 argues the opposite should be tested first.

Scope boundary worth stating early. The subject is a pipeline that produces evidence for human decision-makers. It does not design biological agents or interventions, does not drive laboratory automation, and does not make clinical or regulatory determinations. That boundary is easy to state and harder to establish formally, which is the substance of Section 6.

2 How to read this document

Every substantive claim carries one of three markers reflecting how well it could actually be checked:

[**verified**] Primary source read first-hand, or DOI resolution confirmed directly.

[**secondary**] Confirmed via the official page's indexed content plus at least two independent corroborating sources, but the primary document was not read in full.

[unresolved] Sources conflicted, or the claim could not be corroborated. These are research tasks, not facts, and are collected in Section 9.

The proportion of [SECONDARY] markers is high, and that is a limitation of the review rather than of the sources. The appendix explains why.

3 Starting point: what federation appears to buy

3.1 The encouraging evidence

Biomedical data is rarely poolable: it sits in hospital systems, national laboratories, public-health agencies, contract research organisations and commercial sponsors, under incompatible legal bases. Federated learning moves the model to the data instead [32, 63, 67]. Three results suggest this can produce genuine scientific value rather than only a governance convenience:

- **EXAM** [8] — 20 hospitals across five continents predicting COVID-19 oxygen requirements, reporting average AUC above 0.92 and roughly a 38% average increase in generalisability over single-site models. [SECONDARY]
- **FeTS** [58, 59] — the largest such study to date at 71 sites across 6 continents, $n = 6{,}314$ glioblastoma cases, reporting 33% improvement in delineating the surgically targetable tumour and 23% for complete tumour extent against a publicly-trained model. [SECONDARY]
- **MELLODDY** [23] — ten competing pharmaceutical companies, 2.6 billion confidential activity data points, each reporting model improvements without exposing proprietary data. Evidence that federation can cross *competitive*, not merely institutional, trust boundaries. [SECONDARY]

3.2 The counterweight, which deserves equal billing

These are the published successes, and they required extraordinary institutional effort. The median outcome looks different: Li et al. [37] reviewed healthcare FL through May 2024 and concluded the vast majority of work is not appropriate for clinical use, citing privacy, generalisation and communication deficiencies. [VERIFIED]

A frequently repeated claim holds that only about 5.2% of published healthcare FL studies represent real clinical deployment. The source for this could not be reached and the figure should not be used until checked. **[unresolved]**

3.3 What inverts relative to centralised machine learning

Centralised assumption	Federated reality	Discussed in
One schema, one curation team	N schemas, N curation cultures	Section 4.2
Debug by inspecting the data	You never inspect it; you debug through statistics and contracts	Section 4.3
One trust boundary	Every participant is a dependency *and* a possible adversary	Section 4.5
Availability is one platform's problem	Availability is the product of all participants'	Section 4.6
Model output is the only artifact	Gradients, metrics and loss curves are disclosure channels	Section 4.4

Federation reduces raw-data movement risk. It does not obviously reduce — and may concentrate — model-mediated disclosure risk, data-quality risk and dual-use risk.

3.4 Federation may not be the right answer

Concern. Choosing FL early, on governance grounds, before testing whether a simpler architecture would do.

What the literature says. The **Five Safes** model — safe projects, people, settings, data and outputs — underpins Trusted Research Environments and is the mature alternative for controlled analysis of sensitive data [64]. [SECONDARY] It matters here for a second reason as well: "safe outputs" is *statistical disclosure control*, a discipline with decades of methodology behind it. Any egress mechanism an FL platform builds (Section 4.4) is a re-invention of that discipline unless it binds to it deliberately. The EU's European Health Data Space [13] is converging on the same shape: computation inside a certified secure processing environment, with only anonymised or pseudonymised data leaving.

Worth investigating.

- For the specific scientific question at hand, would a TRE with pooled governed access outperform federation on time-to-result, given the legal bases actually available?
- Is the binding constraint legal, political, or commercial? These have different architectural answers, and conflating them tends to produce FL by default.
- What does the programme lose by never being able to inspect the data, and is that cost acknowledged in the project plan?

4 Concerns

4.1 Scientific validity and site confounding

Concern. A model that performs well across participating sites may be learning the sites rather than the biology, and conventional validation will not reveal it.

What the literature says. This is demonstrated, not hypothetical. Zech et al. [89] trained pneumonia classifiers on 158,323 radiographs across three institutions and found significantly worse performance on outside-hospital images in 3 of 5 comparisons, because the networks identified hospital system and department with high accuracy and calibrated to local disease prevalence. [SECONDARY] Separately, leakage is a widespread rather than occasional failure: Kapoor and Narayanan [35] document it across at least 294 papers in 17 disciplines, offering a taxonomy of eight leakage types and a "model info sheet" as a mitigation. [VERIFIED] On the reporting side, disaggregated evaluation — performance broken down by demographic, phenotypic and intersectional groups — is the defining contribution of model cards [42] and is routinely omitted. [VERIFIED]

Worth investigating.

- Can site, instrument, reagent lot and collection period be *named* as variables for every participating site? If not, claims that the model learned biology rather than logistics are not testable.
- How many genuinely held-out sites are available, and who controls them? Evaluation that reports to the training team is not evaluation.

- Is train/test independence enforced at the site and patient level rather than the sample level? Regulatory guidance already expects this [80], and it is the split most often got wrong.
- What is the pre-registered evaluation plan, and what would count as a negative result?

4.2 Data semantics: what a row means at every site

Concern. The hardest part of federated work is not the learning. It is agreeing what a field means across institutions that never compare raw records — and the failure mode is silent.

What the literature says. A substantial standards ecosystem exists and should be bound to rather than reinvented. Table 1 records what could be established about each, including version details that matter in practice.

Table 1: Standards worth binding to, with version notes. Verified where the domain was reachable; most standards-body sites were blocked from the review environment (see appendix).

Domain	Standard	Notes
Clinical / EHR exchange	HL7 FHIR [21]	R5 (v5.0.0, 2023) is current published; R6 is in normative ballot only. But R4 (v4.0.1) remains the deployment reality for US Core and EHDS work — choose deliberately. [SECONDARY]
Observational analytics	OMOP CDM [56]	v5.5 current, a non-breaking superset of v5.4. v6.0 exists but is *unsupported* by the OHDSI tool stack; never cite it as latest. [VERIFIED]
Clinical trial data	CDISC SDTM, ADaM [5]	SDTM is as-collected tabulation, ADaM analysis-ready with traceability. Version numbers **[unresolved]**.
Nonclinical toxicology	CDISC SEND [5]	SEND is SDTM *applied to the nonclinical domain* — animal toxicology, not clinical. Include only if preclinical safety is in scope. [SECONDARY]
Lab observations	LOINC [61]	Names what was measured, not the result. Free licence. [SECONDARY]
Clinical concepts	SNOMED CT [68]	**Requires a licence** — free in member countries via national release centres, paid otherwise. [SECONDARY]
Units	UCUM [62]	"Unified *Code* for Units of Measure" — singular. [SECONDARY]
Phenotype exchange	GA4GH Phenopackets v2 [17]	Published as ISO 4454:2022, the first GA4GH standard published by ISO. [SECONDARY]
Data resolution	GA4GH DRS v1.5.0 [18]	An ID-to-access-URL resolution layer, *not* a transfer protocol and not a search API. [VERIFIED]
Researcher authorisation	GA4GH AAI v1.2 [19] and Passport v1.2 [20]	**Two distinct specifications** from two work streams. AAI is the OIDC protocol; Passport is the token format. Writing "Passports/AAI" as one thing is imprecise. [VERIFIED]

Domain	Standard	Notes
Imaging de-identification	DICOM PS3.15 Annex E [54]	E.2 Basic Profile plus named Options; Table E.1-1 is the per-attribute action table. **The standard itself states the profiles do not guarantee de-identification and do not replace a de-identification process.** Burned-in pixel data, private tags and free-text descriptors are the residual-risk vectors. [SECONDARY]
Experiment metadata	ISA framework [26]	Domain-neutral community framework, ELIXIR Recommended Interoperability Resource. Not a ratified SDO standard — describe it accurately. [SECONDARY]
Standards discovery	FAIRsharing [39]	The live successor to MIBBI [69] via BioSharing. MIBBI no longer exists as an active registry. [SECONDARY]
Organism identity	NCBI Taxonomy [65]	The nomenclature repository for INSDC. *Not* an authoritative phylogenetic or nomenclatural authority — NCBI says so itself. [SECONDARY]
Provenance	W3C PROV-O [85]	Recommendation since 2013, stable. Cite PROV-O specifically for the RDF ontology. [SECONDARY]
Catalogue metadata	W3C DCAT 3 [86]	Recommendation, August 2024, built on PROV-O terms. The health profile HealthDCAT-AP is separate and evolving — do not conflate. [SECONDARY]
Findability principles	FAIR [87]	See the caveat below: FAIR is not a standard. [VERIFIED]

Three corrections worth recording, because all three are easy mistakes.

- **MIAPPE does not belong in a human biomedical standards set.** It is the *Minimum Information About a Plant Phenotyping Experiment* [41]; its entities are germplasm, growth facility, field plot layout and agronomic treatment. An earlier draft of these notes cited it. That was wrong, and it is the kind of error that signals a standards list assembled without domain checking. [SECONDARY]
- **MINSEQE is orphaned.** The FGED Society dissolved in September 2021. It is citable as a historical checklist only, never as a live standard with a governing body. [SECONDARY]
- **"FAIR compliance" is not a meaningful claim.** FAIR [87] has no conformance test, no version and no certifying body. The defensible phrasing is that a platform *implements* the FAIR principles via DCAT, PROV and persistent identifiers. Note also that *Accessible* does not mean *open* — FAIR explicitly accommodates authenticated, controlled access, which is precisely why GA4GH Passports and AAI are its right companions for human data.

The mechanism that seems to matter most. A versioned, machine-readable *feature contract* per model family — authored centrally, enforced locally — specifying for each field: logical name, semantic type and unit; source code system with version; permissible values and

the action on violation; whether missingness is informative and how it is encoded; derivation as executable code rather than prose; and sensitivity class. Harmonisation then runs at the edge, so mapping logic stays with the people who understand the source system, and mapping bugs surface in conformance reports rather than requiring access to raw records.

Worth investigating.

- Which standard versions will actually be bound, and is every coded field carrying `(system, version, code)`?
- What happens to unmapped values? Silent coercion is the failure mode; an explicit unmapped queue with the original string retained locally is the alternative.
- How are contract versions enforced across a round — can a round silently mix versions?
- Who owns each site's mapping specification, and is an unreviewed mapping change treated as the production change it is?
- Does SNOMED CT licensing actually cover every participating jurisdiction? This is a real blocker that tends to surface late.

4.3 Data quality without being able to look

Concern. Quality must be asserted, tested remotely and attested — and there is a strong temptation to invent a bespoke taxonomy for this.

What the literature says. A canonical framework exists. Kahn et al. [31] is the harmonised terminology for secondary use of EHR data, and it has *two* axes, the second of which is routinely dropped:

Categories Conformance (value, relational, computational); **Completeness**; **Plausibility** (uniqueness, atemporal, temporal). Note the asymmetry — conformance and plausibility have subcategories, completeness does not.

Contexts Verification against internal expectations and metadata; **Validation** against an external gold standard or real-world referent.

[VERIFIED] The OHDSI Data Quality Dashboard [2, 55] operationalises exactly this taxonomy against OMOP as 24 parameterised check types instantiated as more than 3,000 individual checks, each tagged verification or validation. (Those two numbers describe templates and instantiations respectively and are often conflated.) [VERIFIED]

But federated quality assessment has no agreed standard. Kahn supplies terminology, the DQD supplies an OMOP implementation, and the operational patterns come from FDA Sentinel (a coordinating centre distributes check programs, sites execute locally, results return) and PCORnet (which adapted Sentinel's approach to assess "foundational data quality" — fitness across a research portfolio rather than per study). The standard critique is that these are *top-down*: sites must satisfy centrally defined targets rather than assess in local context, and cross-network comparability remains open. [SECONDARY]

Worth investigating.

- Can the programme adopt Kahn's terminology directly, including the verification/validation axis, rather than growing a parallel scheme?
- What is the actual gate policy — are failing sites excluded with a stated reason, or quietly down-weighted? The latter hides the problem in the model.

- How is cross-site duplication *risk* estimated without exchanging identifiers?
- How is label quality established: provenance, adjudication procedure, inter-rater agreement?
- Is there an explicit leakage check for fields encoding the outcome or post-outcome information [35]?
- On deletion: does it propagate to snapshots, caches, checkpoints and derived artifacts, with a per-participant attestation? And does consent withdrawal imply retraining? Removing one subject's influence from a trained model retroactively is expensive and sometimes infeasible, so the answer belongs in the data-use agreement rather than in an incident.

4.4 Privacy: stating precisely what each mechanism guarantees

Concern. Privacy mechanisms are often described in ways that overstate what they deliver, and federation itself is frequently assumed to remove a programme from data-protection scope.

What the literature says. Three findings deserve to be stated exactly.

Secure aggregation [4] gives a communication-efficient, dropout-robust protocol by which a server computes a *sum* over a cohort without learning any individual contribution. [SECONDARY] Its limit: it protects the individual update, not the aggregate. Anything inferable from the sum remains inferable. Secure aggregation and differential privacy are complements, not substitutes.

Gradient inversion is more feasible than often assumed. Geiping et al. [16] reconstruct images at high resolution from parameter gradients, report that input to a fully connected layer is analytically reconstructible independent of the rest of the architecture, and state that averaging gradients over several iterations or several images does *not* protect privacy. [SECONDARY] An earlier draft of these notes offered large cohort sizes as a defence against inversion; that was not supportable.

The unit of privacy is where ε reporting goes wrong. Example-level and client-level differential privacy give materially different guarantees. In a multi-hospital setting the entity needing protection is usually the *patient*, who may contribute many records, so a single-record definition degrades accordingly. An ε reported without its unit, accounting method and composition assumptions is not a privacy claim. [SECONDARY]

End-to-end integration has been demonstrated: PriMIA [33] combines differentially private, securely aggregated federated learning with encrypted inference on paediatric chest radiographs, reporting performance comparable to locally trained models and empirical resistance to a gradient-based inversion attack; see also Kaissis et al. [34]. [SECONDARY]

Data-protection scope. Gradients, embeddings and weights derived from personal data are frequently still personal data under GDPR [9, 11]; federation does not automatically take a programme out of scope. Federated consortia also usually create *joint controllership* rather than processorship, which is an Article 26 arrangement best settled before the first training round. [SECONDARY]

Worth investigating.

- What exactly is the disclosure-control policy on egress — artifact types, shapes, minimum cell sizes, suppression rules — and does it bind to statistical disclosure control practice [64] rather than being bespoke?
- What is the declared unit of privacy, and who enforces the budget? A ledger the platform enforces behaves differently from a convention.
- Are per-site metrics, loss curves and error analyses treated as disclosure channels, or do they circulate informally? The latter is common and rarely reviewed.

- Would a dedicated review of the DP accounting literature change the parameter choices? These notes did not examine it in depth and should not be relied on for it. **[unresolved]**
- Confidential computing is attractive but not a clean answer: side-channel attacks are the primary documented threat to TEEs and enclave memory limits constrain ML workloads [43]. Is it being used as defence in depth or as the privacy argument? [SECONDARY]

4.5 Adversarial robustness, where the literature genuinely disagrees

Concern. The obvious reading of the attack literature is that federated learning is dangerously fragile. The obvious reading of the critique literature is that it is fine. Both readings are available, and an earlier draft of these notes picked a side without acknowledging the dispute.

What the literature says. Laid out in sequence:

- **Attacks succeed under their stated assumptions.** Bagdasaryan et al. [1] show model-replacement backdoors reaching 100% backdoor accuracy in a single round, with an attacker controlling fewer than 1% of participants able to prevent the model from unlearning the backdoor. [SECONDARY]
- **Defences have formal but bounded guarantees.** Krum [3] and coordinate-wise median / trimmed mean [88], the latter with order-optimal statistical error rates under subexponential gradient noise, are the canonical robust estimators. [SECONDARY]
- **The threat models were largely unrealistic.** Shejwalkar et al. [66] systematise the space and conclude that prior work assumed impractically high compromised-client fractions and adversary capability, finding that "FL is highly robust in practice even when using simple, low-cost defenses." [VERIFIED]
- **Defence evaluation remains weak.** Zhang et al. [90] observe that defences are typically evaluated in isolation against limited attack strategies, and benchmark 15 attacks against 17 defences across 2,040 settings. [SECONDARY]

Why the disagreement may not resolve in this setting. Shejwalkar et al. [66] ground their reassurance in *cross-device* production FL with large participant populations. A biomedical consortium is *cross-silo*: few participants, each holding large influence, where a single compromised site is a far larger fraction of the update than in the setting that study examined. The reassurance may simply not transfer. What does appear to transfer, because it does not depend on out-detecting a clever adversary, is contractual and identity vetting at enrollment, bounds enforcement on update norms and per-cohort contribution, per-site influence monitoring, and independent held-out evaluation.

Worth investigating.

- Does any published result characterise poisoning robustness in the cross-silo, few-participant regime specifically? If not, this is a research gap the programme may have to fill itself rather than assume away.
- What bound on any single participant's per-round influence is acceptable, and is it enforced by construction or detected after the fact?
- Is there an isolation procedure for a misbehaving participant, and has it been *rehearsed*? An unrehearsed kill switch is a hypothesis.
- For threat-model vocabulary, NIST AI 100-2e2025 [51] organises attacks by lifecycle stage and attacker goal, capability and knowledge, with an attack/mitigation index. Is the programme's threat model written in a shared vocabulary or an ad hoc one? [SECONDARY]

- Supply chain: SLSA [57] asserts build-platform integrity and in-toto [25] supplies the attestation envelope. The interesting question is whether in-toto predicates can be extended beyond build provenance to *dataset*, *model-weight* and *evaluation-result* attestation, so a model carries a verifiable chain back to its training corpus and its review.

4.6 Reliability when partial participation is normal

Concern. Sites will be unavailable, slow, mid-migration or failing quality gates. A design that treats full participation as the default will stall; but the dominant risk may not be availability at all.

What the literature says. Statistical heterogeneity, not downtime, appears to be the dominant performance risk: non-IID label and feature distributions across sites cause client drift and unstable convergence, and quantity imbalance compounds it. [SECONDARY] The practical implication is that the engineering needed for partial participation — quorum rounds, bounded staleness, per-round checkpointing, idempotent retryable stages, cohort-weighted aggregation with caps — is necessary but will not by itself produce a model that transfers.

Worth investigating.

- What participation floor constitutes a valid round, and is who participated recorded per round?
- What is the straggler and deadline policy, and is it in configuration or decided case by case?
- How much work does a coordinator failure cost, and has recovery been tested by drill rather than argued on paper?
- Which service levels should have *no* error budget? Integrity and privacy objectives are plausible candidates — they are not tradeable against delivery speed in the way latency is.
- Are adversarial and chaos drills scheduled — dropping a site mid-round, corrupting a delta, replaying a stale update, simulating coordinator loss?

5 Regulatory and governance currency

Concern. Compliance artifacts built on remembered rather than checked policy will be wrong, because an unusual amount changed in 2025–2026. This section is the most perishable in the document.

5.1 Medical device and pharmaceutical regimes

- **The FDA PCCP guidance is final** [76] and is arguably the single most consequential document for pipeline architecture. A Predetermined Change Control Plan authorises pre-specified modifications without a new marketing submission, requiring a bounded Description of Modifications, a Modification Protocol (data management, re-training, performance evaluation and acceptance criteria) and an Impact Assessment. The design consequence: a retraining loop, drift monitoring, dataset versioning and acceptance thresholds must be *writable into a Modification Protocol up front*, or each model refresh becomes a new submission. [SECONDARY]
- **The FDA AI device lifecycle guidance remains draft** [78] — issued January 2025, not finalised. Not binding. [SECONDARY]

- **The FDA AI-in-drug-development guidance** [77] introduces a seven-step risk-based Credibility Assessment Framework anchored on Context of Use, implying a credibility dossier *per context of use* rather than per model. Whether a final version issued in 2026 is **[unresolved]**.
- **FDA and EMA published joint AI principles in January 2026** [79] — ten principles, the first such alignment for medicines. [SECONDARY]
- **GMLP principles** [80] are what reviewers actually apply. Principle 4 (independent training and test datasets) dictates splitting at site and patient level; principle 7 evaluates the human–AI team rather than the model alone. [SECONDARY]
- **Lifecycle and quality standards are stable**, which is worth knowing precisely because other things are not: IEC 62304 Edition 1.1 remains current with Edition 2 unpublished [24]; ISO 14971 [28] was reconfirmed in 2025 and its post-production feedback loop is where drift monitoring legally attaches; ISO 13485 [27] was reconfirmed in late 2025 and is incorporated by reference into the FDA QMSR effective February 2026. IEC 62304's *SOUP* provisions are where an ML framework, CUDA stack and any pretrained weights land — a foundation model in a Class C device is SOUP with an awkward anomaly history. [SECONDARY]
- **ALCOA+ maps onto technical controls** more cleanly than its reputation suggests [40, 60]: attributable/contemporaneous to a signed, server-timestamped immutable audit log; original to retaining raw source plus a verified true copy rather than only derived features; enduring/available to readability over a retention period that for biologics may outlive the ML framework itself. [SECONDARY]
- **Draft EU GMP Annex 22 on artificial intelligence** [10] went to consultation in July 2025, closed in October 2025, with final text targeted for Q4 2026 — so not in force. As drafted it would restrict AI in GMP-critical applications to *static, deterministic models*, excluding dynamic and continuously-learning models. A manufacturing decision path that assumes a continuously-learning model is therefore at architectural risk. [SECONDARY]

5.2 EU data and AI law

- **EU AI Act high-risk obligations were deferred.** Regulation (EU) 2024/1689 [12] was amended by Regulation (EU) 2026/1744 [14], in force 27 July 2026 — six days before the original deadline. Annex III standalone high-risk moved from 2 August 2026 to **2 December 2027**; Annex I, which covers AI in MDR/IVDR devices, moved to **2 August 2028**. Prohibited practices, general-purpose AI obligations and Article 50 transparency duties were *not* deferred. [VERIFIED] Any analysis written before July 2026 that assumes an August 2026 bite is now wrong.
- Most clinical AI reaches high-risk via *Annex I rather than Annex III*, because an AI-enabled medical device already requires third-party conformity assessment. Articles 9 and 17 map substantially onto ISO 14971 and ISO 13485; **Article 10 on data and data governance has no clean MDR analogue and is the genuine new work**; Article 12 automatic logging is a hard architectural requirement. [SECONDARY]
- **The GDPR "Data Omnibus" was not adopted.** Only the AI Omnibus passed. Proposed GDPR amendments — including making research processing always purpose-compatible — remain in negotiation, and the EDPB/EDPS joint opinion of February 2026 is strongly critical. Designing to the proposed text would be a mistake. [SECONDARY]

- The **European Health Data Space** [13] is in force since March 2025, with general application March 2027 and the secondary-use regime from **March 2029**: access via national Health Data Access Bodies issuing permits, inside a secure processing environment, with only anonymised or pseudonymised data leaving. Building for that access pattern now is not premature. [SECONDARY]

5.3 Security and AI-risk frameworks

- **NIST SP 800-53** [50] — pin the *release*, not only the revision. Release 5.2.0 (August 2025) adds controls on software resiliency by design, developer testing, secure update and patch deployment, and software integrity. [SECONDARY]
- **NIST CSF 2.0** [49] adds the GOVERN function and strengthened supply-chain outcomes, which is what auditors use to ask who owns model-risk decisions. [SECONDARY]
- **Zero trust** [46] — treat each training job, feature store, model registry and inference endpoint as a separately authenticated subject rather than relying on network perimeter. [SECONDARY]
- **The NIST AI RMF is under active revision** [47] — the NIST AI Resource Center carries a notice to that effect, with no 1.1 or 2.0 published. [VERIFIED] Pin the version and date in any compliance artifact. The Generative AI Profile [48] identifies CBRN information and capability among twelve risk areas. [SECONDARY]
- **ISO/IEC 42001** [29] is a *management system* standard, not a technical AI-safety standard. It provides a governance wrapper; it will not satisfy EU AI Act technical requirements, FDA credibility expectations or any biosecurity control on its own. **ISO/IEC 27701:2025** [30] is now standalone and separately certifiable, with scope expanded to AI-related processing and health data. [SECONDARY]

6 Biosecurity and dual-use: the largest open question

Concern. The governing US policy changed fundamentally in 2026, and whether a computational pipeline of this kind is in scope at all is unresolved.

What the literature says. The 2024 DURC/PEPP policy [81] was overtaken by Executive Order 14292 [73], signed 5 May 2025 — one day before that policy's effective date — which paused federal funding for dangerous gain-of-function research and directed its revision or replacement.

The replacement is the **US Government Policy for Stopping High-Risk Life Sciences Research** [83], approved 20 July 2026 and released 28 July 2026. [VERIFIED] It replaces the 2024 DURC/PEPP policy and the earlier DURC and P3CO policies; shifts from a list-based to a risk-based framework and from "oversee and mitigate" to *prohibit and stop*, establishing federal funding prohibitions rather than only review requirements; introduces two categories, **Dangerous Gain-of-Function (DGOF)** research and **International Research of Concern (IROC)**; restricts federally supported life-sciences research conducted *outside* the United States; and imposes expanded review, certification, monitoring, reporting and enforcement obligations on all institutions receiving federal life-sciences funding.

The question that matters most, and is not answered here. Whether purely computational or in-silico biological design work falls within "life sciences research" under this policy *determines whether a pipeline of this kind is in regulatory scope at all.* The policy text could not be retrieved from the review environment, so the DGOF and IROC definitions are **[unresolved]**.

This should be the first thing read in full. Institutions are meanwhile acting beyond the federal floor — the University of California mandated a pause on work meeting the DGOF definition regardless of funding source, effective May 2026. [SECONDARY]

Other changes that overturn common assumptions.

- **EO 14110 was rescinded** [71] in January 2025; EO 14179 and the July 2025 AI Action Plan [72] are operative. Importantly, *artifacts produced under* EO 14110 — including the NIST AI RMF and agency AI policies — survive its rescission. [SECONDARY]
- **Nucleic acid synthesis screening is in limbo.** The April 2024 OSTP framework [82] made provider attestation a condition of federal research funding, but EO 14292 directed its revision or replacement within 90 days, a deadline that passed in August 2025 with no replacement published. The Sequences of Concern definition is expected to widen. If any part of a pipeline emits sequences for synthesis, the implication is to build provider-attestation verification and an order-level screening audit trail now, and to treat the SOC definition as a configuration value rather than a design assumption. [SECONDARY]
- **AI biological-capability evaluation is by agreement, not regulation.** There is no US statutory requirement to evaluate a model for biological uplift before release; the binding obligations sit in the EU AI Act general-purpose AI systemic-risk regime and in provider-internal frameworks. If a pipeline consumes a frontier model, the enforceable safeguards sit with the provider under EU law and with the consumer contractually. [SECONDARY]
- **Where to put the hardest controls.** The NASEM consensus study [45] assesses AI-enabled biological design tools and finds that AI is also a biosecurity *strengthener*. Its most architecturally useful conclusion is that risk concentrates at the AI-to-wet-lab interface — synthesis and physical execution — rather than in the model itself, which argues for concentrating controls at the design-to-order boundary rather than attempting to gate the model. [SECONDARY]
- **The NIH Guidelines are being replaced.** A draft NIH Biosafety Policy for Research Involving Biohazards [52] was released in August 2026 and would replace the NIH Guidelines [53] entirely, widening scope from recombinant and synthetic nucleic acids to biohazards generally with tiered risk-based oversight. The comment period closed 19 October 2026; the Guidelines remain operative until the replacement is final. Separately, IBC minutes from meetings on or after 1 June 2025 must be posted publicly — so institutional deliberations about a programme should be assumed public. [SECONDARY]

Export control, briefly. Biotech equipment controls tightened in January 2025 with new ECCNs 3A069 and 3E069 [74], the rule's rationale explicitly citing the combination of such equipment with AI and biological design tools. Conversely, **there is currently no general US export control on AI model weights** — the AI Diffusion Rule was rescinded in May 2025 [75] — so a risk register assuming otherwise is wrong. The trap is *deemed export*: releasing controlled technology, including source code and technical data, to a foreign national inside the United States is a licensable event, which means repository, model-weight and sequence-data access control is an export-control surface and not only an HR process. [SECONDARY]

Gate stacking. A countermeasure programme typically passes four to five independent review gates with different owners: institutional biosafety; high-risk/dual-use review; IRB for human data (with single-IRB requirements for NIH-funded multi-site human-subjects research); select agent registration where applicable; and export-control review. The dual-use gate is the one most often discovered late.

7 Documentation and reporting

Concern. There is a temptation to assume a federated-learning reporting standard exists. It does not.

What the literature says. No EQUATOR-registered consensus reporting guideline is specific to federated learning. [SECONDARY] The stage-appropriate general guidelines are summarised in Table 2; confusing SPIRIT-AI (protocol) with CONSORT-AI (report) is the most common error with that pair.

Table 2: Stage-appropriate reporting guidelines. No equivalent exists that is specific to federated learning.

Lifecycle stage	Guideline
Model development / validation	TRIPOD+AI [6] — unifies regression and ML, adds fairness and open-science items
Early-stage live clinical evaluation	DECIDE-AI [84] — human factors and clinician–AI interaction, not accuracy
Trial protocol	SPIRIT-AI [7]
Trial report	CONSORT-AI [38]
Medical imaging AI	CLAIM 2024 Update [70]; cite this, not the 2020 original [44]
Baseline minimum information	MINIMAR [22] — a proposal, not a Delphi-consensus guideline

All DOIs in Table 2 resolve to the correct publisher paths. [VERIFIED] Supplement with FUTURE-AI [36] — 118 experts across 51 countries, a two-year modified-Delphi process, six principles (fairness, universality, traceability, usability, robustness, explainability) expanded into 28 best practices — noting it is a trustworthiness and deployment framework rather than a reporting checklist. [VERIFIED]

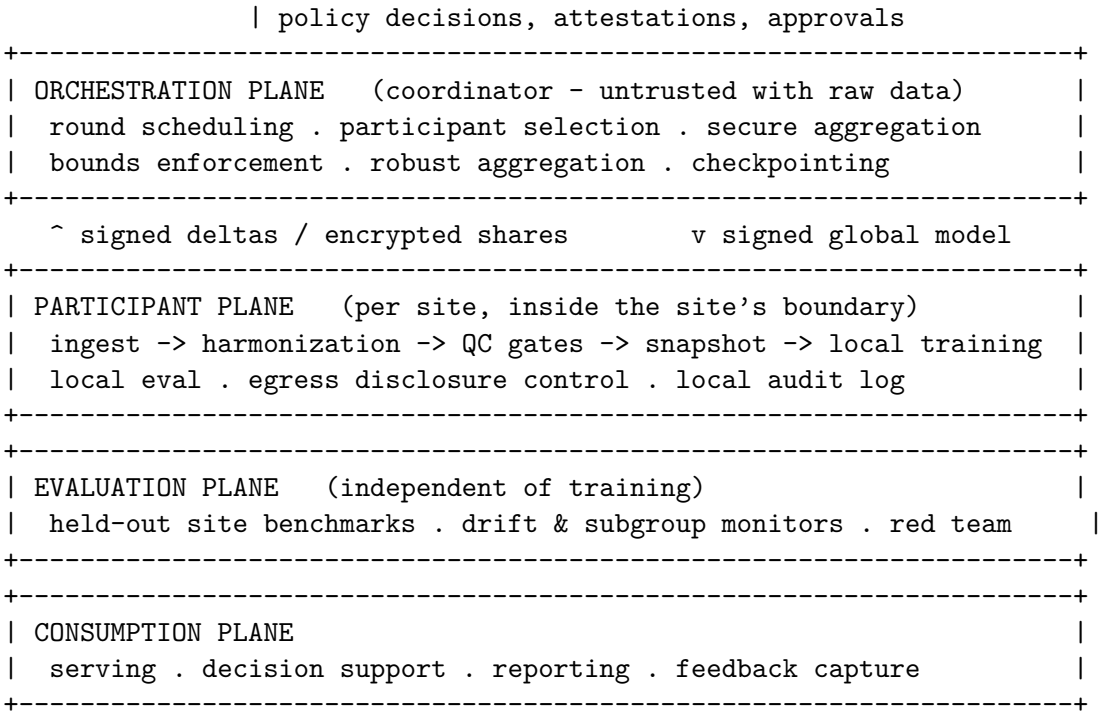
Worth investigating.

- Regardless of which guideline applies, federated studies arguably ought to report site count, per-site sample sizes and distributions, aggregation strategy, communication rounds, privacy mechanism with unit of privacy and ε accounting, and *per-site rather than pooled* performance. Is there appetite to standardise that set?
- Per artifact, three documents seem worth insisting on: a datasheet per dataset snapshot [15], a model card with disaggregated evaluation per model [42], and a model info sheet for leakage [35]. Datasheets are qualitative by design with no conformance criteria, so pairing them with machine-readable DCAT/PROV records is probably necessary.

8 An architecture sketch, offered as a straw man

The following is a plausible shape, included so that it can be argued with. It is not a recommendation, and the concerns above are more important than this diagram.

```
+-------------------------------------------------------------------+
| GOVERNANCE PLANE                                                  |
|  enrollment & identity . data-use agreements . approvals          |
|  privacy-budget ledger . model registry . immutable audit log     |
+-------------------------------------------------------------------+
```



The propositions embedded in it, each of which is contestable:

1. The coordinator is untrusted with data and should be designed as though it will be breached.
2. Egress is an enforced chokepoint implementing statistical disclosure control, default-deny.
3. Evaluation does not report to training — different owners, different credentials, separate held-out data.
4. Reproducibility is infrastructure: content-addressed artifacts, pinned digests, a run manifest per round.
5. Governance is enforced in code paths, since an approval that exists only in a document is not a control.

9 Consolidated investigation agenda

Ordered by how much the answer would change the design.

1. **Read the July 2026 *Stopping High-Risk Life Sciences Research* policy in full** [83] — specifically the DGOF and IROC definitions, and whether in-silico design is in scope. This determines scope exposure more than anything else here, and is currently unresolved.
2. **Decide federation versus a Trusted Research Environment** on evidence rather than by default (Section 3.4), including what is lost by never inspecting the data.
3. **Establish whether poisoning robustness has been characterised in the cross-silo, few-participant regime** (Section 4.5). If not, it is a gap to fill rather than assume away.
4. **If a regulated device is plausible, draft the PCCP Modification Protocol early** [76] — it constrains retraining, drift monitoring, dataset versioning and acceptance thresholds downstream.

5. **Commission a dedicated review of DP accounting and the unit of privacy.** These notes establish that the question matters but do not settle the parameter choices.
6. **Verify CDISC version numbers** directly (Table 1) — currently low confidence.
7. **Confirm whether the FDA January 2025 AI-in-drug-development draft was finalised** [77] — sources conflicted.
8. **Verify SLSA v1.2 level semantics** first-hand [57].
9. **Track the replacement nucleic acid synthesis screening framework** [82] and keep the Sequences of Concern definition configurable.
10. **Check the "5.2% of healthcare FL studies are real deployments" figure** before it is used anywhere.

Signals that a programme is drifting. Raw data requested "just to debug"; per-site metrics circulating informally; mapping changes without review; a benchmark the training team can see; an isolation procedure never exercised; a model card written after the model shipped; privacy parameters chosen to hit an accuracy target; a dual-use determination deferred to "later".

A Verification limits

These notes were compiled in an environment whose network egress proxy blocked most standards-body, regulator and publisher domains — including `nature.com`, PubMed Central, ScienceDirect, `hl7.org`, `cdisc.org`, `dicom.nema.org`, `w3.org`, `nist.gov`, `fda.gov`, `whitehouse.gov`, `eur-lex.europa.eu` and `iso.org`. Reachable: `arxiv.org`, `doi.org` for resolution, `raw.githubusercontent.com`, and search indexes.

Consequently most citations are marked [SECONDARY]: DOIs were resolution- tested and official URLs were drawn from official-domain search hits rather than constructed, but the primary documents were largely not read in full. Two claims with the highest stakes — the EU AI Act deferral [14] and the existence and effect of the 2026 high-risk life sciences policy [83] — were verified independently. The full text of the latter was still not obtainable, which is why Section 6 leaves its central question open rather than inferring an answer.

Widening the network allowlist would materially raise confidence in Table 1 and Sections 5 and 6. Until then, the evidence markers should be taken literally: [SECONDARY] means corroborated but not read, and **[unresolved]** means do not rely on it.

References

[1] Eugene Bagdasaryan, Andreas Veit, Yiqing Hua, Deborah Estrin, and Vitaly Shmatikov. How to backdoor federated learning. In *Proceedings of the 23rd International Conference on Artificial Intelligence and Statistics (AISTATS 2020)*, volume 108, 2020. URL `https://proceedings.mlr.press/v108/bagdasaryan20a.html`. secondary.

[2] Clair Blacketer, Frank J. Defalco, Patrick B. Ryan, and Peter R. Rijnbeek. Increasing trust in real-world evidence through evaluation of observational data quality. *Journal of the American Medical Informatics Association*, 28(10):2251–2257, 2021. doi: 10.1093/jamia/ocab132. verified via DOI resolution; the OHDSI Data Quality Dashboard.

[3] Peva Blanchard, El Mahdi El Mhamdi, Rachid Guerraoui, and Julien Stainer. Machine learning with adversaries: Byzantine tolerant gradient descent. In *Advances in Neural Information Processing Systems 30 (NIPS 2017)*, 2017. secondary; the Krum aggregator.

[4] Keith Bonawitz, Vladimir Ivanov, Ben Kreuter, Antonio Marcedone, H. Brendan McMahan, Sarvar Patel, Daniel Ramage, Aaron Segal, and Karn Seth. Practical secure aggregation for privacy-preserving machine learning. In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS '17)*, pages 1175–1191, 2017. doi: 10.1145/3133956.3133982. URL `https://dl.acm.org/doi/10.1145/3133956.3133982`. secondary.

[5] Clinical Data Interchange Standards Consortium. CDISC foundational standards: SDTM, ADaM, SEND. `https://www.cdisc.org/standards`. unresolved on version numbers; cdisc.org unreachable from the review environment. SEND is SDTM applied to the nonclinical (animal toxicology) domain.

[6] Gary S. Collins, Karel G. M. Moons, Paula Dhiman, Richard D. Riley, Andrew L. Beam, Ben Van Calster, Marzyeh Ghassemi, Xiaoxuan Liu, Johannes B. Reitsma, Maarten van Smeden, et al. TRIPOD+AI statement: updated guidance for reporting clinical prediction models that use regression or machine learning methods. *BMJ*, 385:e078378, 2024. doi: 10.1136/bmj-2023-078378. verified via DOI resolution.

[7] Samantha Cruz Rivera, Xiaoxuan Liu, An-Wen Chan, Alastair K. Denniston, and Melanie J. Calvert. Guidelines for clinical trial protocols for interventions involving artificial intelligence: the SPIRIT-AI extension. *Nature Medicine*, 26(9):1351–1363, 2020. doi: 10.1038/s41591-020-1037-7. verified via DOI resolution; SPIRIT-AI covers the protocol.

[8] Ittai Dayan, Holger R. Roth, Aoxiao Zhong, Ahmed Harouni, Amilcare Gentili, Anas Z. Abidin, et al. Federated learning for predicting clinical outcomes in patients with COVID-19. *Nature Medicine*, 27(10):1735–1743, 2021. doi: 10.1038/s41591-021-01506-3. URL `https://www.nature.com/articles/s41591-021-01506-3`. secondary; the EXAM study.

[9] European Data Protection Board. Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models, December 2024. URL `https://edpb.europa.eu`. secondary.

[10] European Medicines Agency / PIC/S GMP-GDP Inspectors Working Group. Draft EU GMP annex 22: Artificial intelligence, and revised annex 11. Published for consultation 7 July 2025; consultation closed 7 October 2025; final text targeted Q4 2026, July 2025. secondary; as drafted, would restrict AI in GMP-critical applications to static, deterministic models.

[11] European Parliament and Council of the European Union. Regulation (EU) 2016/679 (general data protection regulation), 2016. secondary; Arts. 5(1)(b), 9(2)(j), 25, 26, 32, 35, 89 and Chapter V are the provisions most relevant to federated biomedical analysis.

[12] European Parliament and Council of the European Union. Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (artificial intelligence act), 2024. secondary; in force 1 August 2024.

[13] European Parliament and Council of the European Union. Regulation (EU) 2025/327 on the european health data space, 2025. secondary; in force 26 March 2025; secondary-use regime applies from 26 March 2029.

[14] European Parliament and Council of the European Union. Regulation (EU) 2026/1744 amending regulations (EU) 2024/1689, (EU) 2018/1139 and (EU) 2023/1230 as regards the simplification of harmonised rules on artificial intelligence (digital omnibus on AI), July 2026. URL `https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng`. verified independently; OJ 24 July 2026, in force 27 July 2026. Defers Annex III high-risk obligations to 2 December 2027 and Annex I to 2 August 2028.

[15] Timnit Gebru, Jamie Morgenstern, Briana Vecchione, Jennifer Wortman Vaughan, Hanna Wallach, Hal Daumé III, and Kate Crawford. Datasheets for datasets. *Communications of the ACM*, 64(12):86–92, 2021. doi: 10.1145/3458723. verified; arXiv preprint 1803.09010.

[16] Jonas Geiping, Hartmut Bauermeister, Hannah Dröge, and Michael Moeller. Inverting gradients — how easy is it to break privacy in federated learning? In *Advances in Neural Information Processing Systems 33 (NeurIPS 2020)*, 2020. URL `https://arxiv.org/abs/2003.14053`. secondary.

[17] Global Alliance for Genomics and Health. GA4GH phenopacket schema v2. `https://www.ga4gh.org/product/phenopackets/`, 2022. secondary; published as ISO 4454:2022, the first GA4GH standard published by ISO.

[18] Global Alliance for Genomics and Health, Cloud Work Stream. GA4GH data repository service (DRS) API v1.5.0. `https://github.com/ga4gh/data-repository-service-schemas`. verified via repository; an ID-to-access-URL resolution layer, not a transfer or search protocol.

[19] Global Alliance for Genomics and Health, Data Security Work Stream. GA4GH authentication and authorization infrastructure (AAI) v1.2. `https://ga4gh.github.io/data-security/`. verified via specification source; distinct from the Passport specification.

[20] Global Alliance for Genomics and Health, Data Use and Researcher Identity Work Stream. GA4GH passport v1.2. `https://ga4gh-duri.github.io/researcher_ids/ga4gh_passport_v1.html`. verified via specification source.

[21] Health Level Seven International. HL7 FHIR — fast healthcare interoperability resources. `https://hl7.org/fhir/`, 2023. secondary; R5 (v5.0.0, March 2023) current published, R6 in normative ballot, R4 (v4.0.1) the deployment reality.

[22] Tina Hernandez-Boussard, Selen Bozkurt, John P. A. Ioannidis, and Nigam H. Shah. MINIMAR (MINimum information for medical AI reporting): Developing reporting standards for artificial intelligence in health care. *Journal of the American Medical Informatics Association*, 27(12):2011–2015, 2020. doi: 10.1093/jamia/ocaa088. verified via DOI resolution; a proposal rather than a Delphi-consensus guideline.

[23] Wouter Heyndrickx, Lewis Mervin, Tobias Morawietz, Noe Sturm, Lukas Friedrich, Adam Zalewski, et al. MELLODDY: Cross-pharma federated learning at unprecedented scale unlocks benefits in QSAR without compromising proprietary information. *Journal of Chemical Information and Modeling*, 2024. doi: 10.1021/acs.jcim.3c00799. URL `https://pubs.acs.org/doi/10.1021/acs.jcim.3c00799`. secondary.

[24] IEC. IEC 62304:2006/Amd 1:2015 — medical device software — software life cycle processes (edition 1.1). `https://www.iso.org/standard/64686.html`, 2015. secondary; corrected version November 2017. Edition 2 not published as of late 2026.

[25] in-toto project. in-toto attestation framework v1.2.0. `https://github.com/in-toto/attestation`. verified via release tags.

[26] ISA Community. The ISA framework (investigation–study–assay). `https://isa-tools.org/`. secondary; community metadata framework, ELIXIR Recommended Interoperability Resource, not a ratified SDO standard.

[27] ISO. ISO 13485:2016 — medical devices — quality management systems, 2016. secondary; reconfirmed 31 October 2025. Incorporated by reference into the FDA QMSR, effective 2 February 2026.

[28] ISO. ISO 14971:2019 — medical devices — application of risk management to medical devices, 2019. secondary; systematically reviewed and confirmed March 2025.

[29] ISO/IEC. ISO/IEC 42001:2023 — information technology — artificial intelligence — management system. https://www.iso.org/standard/42001, 2023. secondary; a management-system standard, not a technical AI-safety standard.

[30] ISO/IEC. ISO/IEC 27701:2025 — privacy information management systems. https://www.iso.org/standard/27701, 2025. secondary; 2nd edition, 14 October 2025 — now a standalone standard, no longer an extension to ISO/IEC 27001.

[31] Michael G. Kahn, Tiffany J. Callahan, Juliana Barnard, Alan E. Bauck, Jeff Brown, Bruce N. Davidson, Hossein Estiri, Carsten Goerg, Erin Holve, Steven G. Johnson, Siaw-Teng Liaw, Marianne Hamilton-Lopez, Daniella Meeker, Toan C. Ong, Patrick Ryan, Ning Shang, Nicole G. Weiskopf, Chunhua Weng, Meredith N. Zozus, and Lisa Schilling. A harmonized data quality assessment terminology and framework for the secondary use of electronic health record data. *eGEMs (Generating Evidence and Methods to improve patient outcomes)*, 4(1):1244, 2016. doi: 10.13063/2327-9214.1244. verified via DOI resolution.

[32] Peter Kairouz, H. Brendan McMahan, Brendan Avent, Aurélien Bellet, Mehdi Bennis, Arjun Nitin Bhagoji, et al. Advances and open problems in federated learning. *Foundations and Trends in Machine Learning*, 14(1–2), 2021. URL https://arxiv.org/abs/1912.04977. secondary.

[33] Georgios Kaissis, Alexander Ziller, Jonathan Passerat-Palmbach, Théo Ryffel, Dmitrii Usynin, Andrew Trask, et al. End-to-end privacy preserving deep learning on multi-institutional medical imaging. *Nature Machine Intelligence*, 3:473–484, 2021. doi: 10.1038/s42256-021-00337-8. secondary; the PriMIA framework.

[34] Georgios A. Kaissis, Marcus R. Makowski, Daniel Rückert, and Rickmer F. Braren. Secure, privacy-preserving and federated machine learning in medical imaging. *Nature Machine Intelligence*, 2(6):305–311, 2020. doi: 10.1038/s42256-020-0186-1. secondary.

[35] Sayash Kapoor and Arvind Narayanan. Leakage and the reproducibility crisis in machine-learning-based science. *Patterns*, 4(9):100804, 2023. doi: 10.1016/j.patter.2023.100804. URL https://www.cell.com/patterns/fulltext/S2666-3899(23)00159-9. verified; arXiv preprint 2207.07048 carries the variant title "Leakage and the Reproducibility Crisis in ML-based Science".

[36] Karim Lekadir, Alejandro F. Frangi, Antonio R. Porras, Ben Glocker, Celia Cintas, Curtis P. Langlotz, et al. FUTURE-AI: International consensus guideline for trustworthy and deployable artificial intelligence in healthcare, 2025. URL https://arxiv.org/abs/2309.12325. verified; 118 experts across 51 countries; also published in BMJ.

[37] Ming Li, Pengcheng Xu, Junjie Hu, Zeyu Tang, and Guang Yang. From challenges and pitfalls to recommendations and opportunities: Implementing federated learning in healthcare, 2024. URL https://arxiv.org/abs/2409.09727. verified; abstract read first-hand. Also published in Medical Image Analysis (2025).

[38] Xiaoxuan Liu, Samantha Cruz Rivera, David Moher, Melanie J. Calvert, and Alastair K. Denniston. Reporting guidelines for clinical trial reports for interventions involving artificial intelligence: the CONSORT-AI extension. *Nature Medicine*, 26(9):1364–1374, 2020. doi: 10.1038/s41591-020-1034-x. verified via DOI resolution; CONSORT-AI covers the trial report. Co-published simultaneously in BMJ and Lancet Digital Health.

[39] Peter McQuilton, Alejandra Gonzalez-Beltran, Philippe Rocca-Serra, Milo Thurston, Allyson Lister, Eamonn Maguire, and Susanna-Assunta Sansone. BioSharing: curated and crowd-sourced metadata standards, databases and data policies in the life sciences. *Database*, 2016:baw075, 2016. doi: 10.1093/database/baw075. secondary; now FAIRsharing, `https://fairsharing.org/`.

[40] Medicines and Healthcare products Regulatory Agency. 'GXP' data integrity guidance and definitions, revision 1, March 2018. secondary; formalizes ALCOA+.

[41] MIAPPE Consortium. MIAPPE: Minimum information about a plant phenotyping experiment. `https://www.miappe.org/`. secondary; cited here ONLY to record that it is plant-specific and does not belong in a human biomedical standards set.

[42] Margaret Mitchell, Simone Wu, Andrew Zaldivar, Parker Barnes, Lucy Vasserman, Ben Hutchinson, Elena Spitzer, Inioluwa Deborah Raji, and Timnit Gebru. Model cards for model reporting. In *Proceedings of the Conference on Fairness, Accountability, and Transparency (FAT* '19)*, pages 220–229, 2019. doi: 10.1145/3287560.3287596. verified; the venue was FAT*, renamed ACM FAccT in 2020.

[43] Saeid Mofrad, Ishtiaq Ahmed, Sean Peisert, et al. SoK: Limitations of confidential computing via trusted execution environments for high-performance compute systems. `https://www.cs.ucdavis.edu/~peisert/research/2022-SEED-TEE-SOK.pdf`, 2022. secondary.

[44] John Mongan, Linda Moy, and Charles E. Kahn. Checklist for artificial intelligence in medical imaging (CLAIM): A guide for authors and reviewers. *Radiology: Artificial Intelligence*, 2 (2):e200029, 2020. doi: 10.1148/ryai.2020200029. verified via DOI resolution; superseded by the 2024 update.

[45] National Academies of Sciences, Engineering, and Medicine. *The Age of AI in the Life Sciences: Benefits and Biosecurity Considerations*. The National Academies Press, Washington, DC, 2025. URL `https://nap.nationalacademies.org/catalog/28868`. secondary; finds risk concentrates at the AI-to-wet-lab interface rather than in the model itself.

[46] National Institute of Standards and Technology. Zero trust architecture. Technical Report NIST SP 800-207, National Institute of Standards and Technology, August 2020. URL `https://csrc.nist.gov/pubs/sp/800/207/final`. secondary; see also SP 800-207A (2023) for cloud-native multi-cloud access control.

[47] National Institute of Standards and Technology. Artificial intelligence risk management framework (AI RMF 1.0). Technical Report NIST AI 100-1, National Institute of Standards and Technology, January 2023. URL `https://www.nist.gov/itl/ai-risk-management-framework`. verified that the NIST AI Resource Center carries a notice that AI RMF 1.0 is being updated; no 1.1/2.0 published as of late 2026.

[48] National Institute of Standards and Technology. Artificial intelligence risk management framework: Generative artificial intelligence profile. Technical Report NIST AI 600-1, National Institute of Standards and Technology, July 2024. URL `https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf`. secondary; identifies CBRN information and capability among twelve generative-AI risk areas.

[49] National Institute of Standards and Technology. The NIST cybersecurity framework (CSF) 2.0. Technical Report NIST CSWP 29, National Institute of Standards and Technology, February 2024. URL `https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final`. secondary; adds the GOVERN function.

[50] National Institute of Standards and Technology. Security and privacy controls for information systems and organizations. Technical Report NIST SP 800-53 Rev. 5, Release 5.2.0, National Institute of Standards and Technology, August 2025. URL https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final. secondary; pin the release, not only the revision.

[51] National Institute of Standards and Technology. Adversarial machine learning: A taxonomy and terminology of attacks and mitigations. Technical Report NIST AI 100-2e2025, National Institute of Standards and Technology, March 2025. URL https://csrc.nist.gov/pubs/ai/100/2/e2025/final. secondary; supersedes the 2023 edition.

[52] National Institutes of Health. Draft NIH biosafety policy for research involving biohazards. Released 19 August 2026; comment period closed 19 October 2026, August 2026. URL https://grants.nih.gov/grants/guide/notice-files/NOT-OD-26-112.html. secondary; would replace the NIH Guidelines entirely.

[53] National Institutes of Health, Office of Science Policy. NIH guidelines for research involving recombinant or synthetic nucleic acid molecules. URL https://osp.od.nih.gov/policies/biosafety-and-biosecurity-policy/. secondary; operative but being replaced. IBC minutes from meetings on or after 1 June 2025 must be posted publicly.

[54] NEMA / DICOM Standards Committee. DICOM PS3.15 annex e: Attribute confidentiality profiles. https://dicom.nema.org/medical/dicom/current/output/chtml/part15/chapter_E.html. secondary; the standard states the profiles do not guarantee de-identification and do not replace a de-identification process.

[55] Observational Health Data Sciences and Informatics (OHDSI). OHDSI data quality dashboard. https://github.com/OHDSI/DataQualityDashboard, . secondary.

[56] Observational Health Data Sciences and Informatics (OHDSI). OMOP common data model. https://ohdsi.github.io/CommonDataModel/, . verified via repository README; v5.5 current, a non-breaking superset of v5.4; v6.0 unsupported by OHDSI tooling.

[57] Open Source Security Foundation (OpenSSF). SLSA: Supply-chain levels for software artifacts, specification v1.2. https://slsa.dev/spec/v1.2/, 2025. secondary; slsa.dev unreachable from the review environment. v1.2 approved 12 November 2025, adding the Source Track.

[58] Sarthak Pati, Ujjwal Baid, Brandon Edwards, Micah Sheller, Shih-Han Wang, G. Anthony Reina, et al. Federated learning enables big data for rare cancer boundary detection. *Nature Communications*, 13(1):7346, 2022. doi: 10.1038/s41467-022-33407-5. URL https://www.nature.com/articles/s41467-022-33407-5. secondary; the FeTS study.

[59] Sarthak Pati, Ujjwal Baid, Brandon Edwards, et al. Author correction: Federated learning enables big data for rare cancer boundary detection. *Nature Communications*, 2023. doi: 10.1038/s41467-023-36188-7. URL https://www.nature.com/articles/s41467-023-36188-7. secondary; cite alongside pati2022federated.

[60] Pharmaceutical Inspection Co-operation Scheme. Good practices for data management and integrity in regulated GMP/GDP environments, July 2021. URL https://picscheme.org/docview/4234. secondary; the most broadly adopted data-integrity guidance.

[61] Regenstrief Institute. LOINC — logical observation identifiers names and codes. https://loinc.org/. secondary; identifies what was measured, not the result.

[62] Regenstrief Institute and the UCUM Organization. The unified code for units of measure (UCUM). https://ucum.org/. secondary.

[63] Nicola Rieke, Jonny Hancox, Wenqi Li, Fausto Milletarì, Holger R. Roth, Shadi Albarqouni, Spyridon Bakas, Mathieu N. Galtier, Bennett A. Landman, Klaus Maier-Hein, Sébastien Ourselin, Micah Sheller, Ronald M. Summers, Andrew Trask, Daguang Xu, Maximilian Baust, and M. Jorge Cardoso. The future of digital health with federated learning. *npj Digital Medicine*, 3:119, 2020. doi: 10.1038/s41746-020-00323-1. URL `https://www.nature.com/articles/s41746-020-00323-1`. secondary.

[64] Felix Ritchie. The five safes framework for trusted research environments. `https://www.dundee.ac.uk/tre/safe-settings/five-safes-framework`. secondary; framework originated at the UK Office for National Statistics.

[65] Conrad L. Schoch, Stacy Ciufo, Mikhail Domrachev, Carol L. Hotton, Sivakumar Kannan, Rogneda Khovanskaya, et al. NCBI taxonomy: a comprehensive update on curation, resources and tools. *Database*, 2020:baaa062, 2020. doi: 10.1093/database/baaa062. secondary; a curated classification for sequence records, not a nomenclatural authority.

[66] Virat Shejwalkar, Amir Houmansadr, Peter Kairouz, and Daniel Ramage. Back to the drawing board: A critical evaluation of poisoning attacks on production federated learning. In *2022 IEEE Symposium on Security and Privacy (SP)*, 2022. URL `https://arxiv.org/abs/2108.10241`. verified; abstract read first-hand.

[67] Micah J. Sheller, Brandon Edwards, G. Anthony Reina, Jason Martin, Sarthak Pati, Aikaterini Kotrotsou, Mikhail Milchenko, Weilin Xu, Daniel Marcus, Rivka R. Colen, and Spyridon Bakas. Federated learning in medicine: facilitating multi-institutional collaborations without sharing patient data. *Scientific Reports*, 10(1):12598, 2020. doi: 10.1038/s41598-020-69250-1. secondary.

[68] SNOMED International. SNOMED CT. `https://www.snomed.org/`. secondary; requires a licence — free in member countries via national release centres, paid otherwise.

[69] Chris F. Taylor, Dawn Field, Susanna-Assunta Sansone, et al. Promoting coherent minimum reporting guidelines for biological and biomedical investigations: the MIBBI project. *Nature Biotechnology*, 26(8):889–896, 2008. doi: 10.1038/nbt.1411. secondary; historical — superseded by BioSharing, then FAIRsharing.

[70] Ali S. Tejani, Michail E. Klontzas, Anthony A. Gatti, John T. Mongan, Linda Moy, Seong Ho Park, and Charles E. Kahn. Checklist for artificial intelligence in medical imaging (CLAIM): 2024 update. *Radiology: Artificial Intelligence*, 6(4):e240300, 2024. doi: 10.1148/ryai.240300. verified via DOI resolution.

[71] The White House. Executive order 14110: Safe, secure, and trustworthy development and use of artificial intelligence, October 2023. secondary; RESCINDED 20 January 2025 by EO 14148. Artifacts produced under it, including the NIST AI RMF, survive.

[72] The White House. Winning the AI race: America's AI action plan, July 2025. secondary; successor policy document to EO 14110 section 4.4 on biosecurity.

[73] The White House. Executive order 14292: Improving the safety and security of biological research, May 2025. URL `https://www.govinfo.gov/app/details/DCPD-202500561`. secondary; signed 5 May 2025.

[74] U.S. Bureau of Industry and Security. Controls on certain laboratory equipment and related technology to address dual use concerns about biotechnology. Interim Final Rule; Federal Register 16 January 2025, January 2025. URL `https://www.federalregister.gov/documents/2025/01/16/2025-00723/controls-`

on-certain-laboratory-equipment-and-related-technology-to-address-dual-use-concerns-about. secondary; creates ECCN 3A069 and 3E069.

[75] U.S. Bureau of Industry and Security. Rescission of the framework for artificial intelligence diffusion, May 2025. URL https://www.bis.gov/press-release/department-commerce-announces-rescission-biden-era-artificial-intelligence-diffusion-rule-strengthens. secondary; rescinded 12 May 2025. There is consequently no general US export control on AI model weights as such.

[76] U.S. Food and Drug Administration. Marketing submission recommendations for a predetermined change control plan for artificial intelligence-enabled device software functions. Final guidance; Federal Register notice 4 December 2024, Docket FDA-2022-D-2628, December 2024. URL https://www.fda.gov/regulatory-information/search-fda-guidance-documents/marketing-submission-recommendations-predetermined-change-control-plan-artificial-intelligence. secondary.

[77] U.S. Food and Drug Administration. Considerations for the use of artificial intelligence to support regulatory decision-making for drug and biological products. Draft guidance, Federal Register 7 January 2025, January 2025. URL https://www.fda.gov/regulatory-information/search-fda-guidance-documents/considerations-use-artificial-intelligence-support-regulatory-decision-making-drug-and-biological. unresolved on whether a final version issued in 2026.

[78] U.S. Food and Drug Administration. Artificial intelligence-enabled device software functions: Lifecycle management and marketing submission recommendations. Draft guidance, 7 January 2025; not finalized as of late 2026, January 2025. URL https://www.fda.gov/media/184856/download. secondary; draft — do not cite as binding.

[79] U.S. Food and Drug Administration and European Medicines Agency. Guiding principles of good AI practice in drug development, January 2026. URL https://www.fda.gov/about-fda/artificial-intelligence-drug-development/guiding-principles-good-ai-practice-drug-development. secondary; ten joint principles, published 14 January 2026.

[80] U.S. Food and Drug Administration, Health Canada, and MHRA. Good machine learning practice for medical device development: Guiding principles, October 2021. URL https://www.fda.gov/media/153486/download. secondary; ten principles. Principle 4 requires independent training and test datasets.

[81] U.S. Office of Science and Technology Policy. United states government policy for oversight of dual use research of concern and pathogens with enhanced pandemic potential, May 2024. secondary; RESCINDED — replaced by the 2026 policy below.

[82] U.S. Office of Science and Technology Policy. Framework for nucleic acid synthesis screening, April 2024. URL https://aspr.hhs.gov/S3/Pages/OSTP-Framework-for-Nucleic-Acid-Synthesis-Screening.aspx. secondary; EO 14292 directed revision or replacement within 90 days; no replacement published as of late 2026.

[83] U.S. Office of Science and Technology Policy. United states government policy for stopping high-risk life sciences research. Approved 20 July 2026; released 28 July 2026, July 2026. URL https://www.aspr.gov/readiness-response/medical-countermeasures-biodefense/s3/high-consequence-research-oversight/USG-Policy-For-Stopping-High-Risk-Life-Sciences-Research. verified independently that this policy exists and replaces the 2024 DURC/PEPP policy. The full text could NOT be retrieved; the DGOF and IROC definitions, and whether in-silico work is in scope, remain unresolved.

[84] Baptiste Vasey, Myura Nagendran, Bruce Campbell, David A. Clifton, Gary S. Collins, Spiros Denaxas, Alastair K. Denniston, Livia Faes, Bart Geerts, Mudathir Ibrahim, et al. Reporting guideline for the early-stage clinical evaluation of decision support systems driven by artificial intelligence: DECIDE-AI. *Nature Medicine*, 28(5):924–933, 2022. doi: 10.1038/s41591-022-01772-9. verified via DOI resolution.

[85] W3C. PROV-O: The PROV ontology. `https://www.w3.org/TR/prov-o/`, 2013. secondary; W3C Recommendation, 30 April 2013.

[86] W3C. Data catalog vocabulary (DCAT) — version 3. `https://www.w3.org/TR/vocab-dcat-3/`, 2024. secondary; W3C Recommendation, 22 August 2024.

[87] Mark D. Wilkinson, Michel Dumontier, IJsbrand Jan Aalbersberg, Gabrielle Appleton, Myles Axton, Arie Baak, Niklas Blomberg, Jan-Willem Boiten, Luiz Bonino da Silva Santos, Philip E. Bourne, et al. The FAIR guiding principles for scientific data management and stewardship. *Scientific Data*, 3:160018, 2016. doi: 10.1038/sdata.2016.18. verified via DOI resolution.

[88] Dong Yin, Yudong Chen, Kannan Ramchandran, and Peter Bartlett. Byzantine-robust distributed learning: Towards optimal statistical rates. In *Proceedings of the 35th International Conference on Machine Learning (ICML 2018)*, 2018. URL `https://arxiv.org/abs/1803.01498`. secondary; coordinate-wise median and trimmed mean.

[89] John R. Zech, Marcus A. Badgeley, Manway Liu, Anthony B. Costa, Joseph J. Titano, and Eric Karl Oermann. Variable generalization performance of a deep learning model to detect pneumonia in chest radiographs: A cross-sectional study. *PLOS Medicine*, 15(11): e1002683, 2018. doi: 10.1371/journal.pmed.1002683. URL `https://journals.plos.org/plosmedicine/article?id=10.1371/journal.pmed.1002683`. secondary.

[90] Heng Zhang et al. SoK: Benchmarking poisoning attacks and defenses in federated learning, 2025. URL `https://arxiv.org/abs/2502.03801`. secondary; the FLPoison benchmark.